

State of Maine

Department of Administrative and Financial Services

Office of Information Technology

System and Communication Protection Policy and Procedures (SC)

Table of Contents

1.0. Document Purpose 3
2.0. Scope 3
3.0. Policy Conflict 3
4.0. Roles and Responsibilities 3
5.0. Management Commitment 4
6.0. Coordination Among Agency Entities 4
7.0. Compliance 4
8.0. Procedures 5
9.0. Document Details 16
10.0. Review 16
11.0. Records Management 16
12.0. Public Records Exceptions 16
13.0. Definitions 17
14.0. Abbreviations 19

1.0. Document Purpose

The purpose of this document is to define the State of Maine policy and procedures that are in place to protect Agency information systems and their communications for State of Maine information assets (see Definitions). This part of the security program focuses on protecting the confidentiality, integrity, accuracy, and consistency (validity) of data throughout its lifecycle. Guarding the integrity of information assets against improper modification or destruction includes ensuring information nonrepudiation and authenticity (see Definitions), integrity (see Definitions), and availability (see Definitions) of State information assets. This document corresponds to the System and Communication Protection Policy and Procedures (SC) Control Family of National Institute of Standards and Technology (NIST) Special Publication 800-53 (Rev. 5).

2.0. Scope

2.1. This policy applies to State of Maine employees and contractors (collectively referred to as personnel in this document) with access to:

2.1.1. Executive Branch Agency information assets, irrespective of location; and

2.1.2. Information assets from other State government branches that use Executive Branch-managed services.

3.0. Policy Conflict

If this policy conflicts with any applicable law or union contract, the terms of the existing law or contract shall prevail.

4.0. Roles and Responsibilities

4.1. Agencies:

4.1.1. Ensure this Policy and Procedures are enforced.

4.2. Application Development Teams:

4.2.1. Maintain data flow diagrams.

4.3. Chief Information Security Officer (CISO):

4.3.1. Owns, executes, and enforces this Policy and Procedures.

4.3.2. Implements security policies, standards, and controls.

4.4. IT Procurement:

4.4.1. In collaboration with Agency Business Partners and Office of Information Technology (OIT) Information Asset Owners, holds all vendors/partners for externally hosted information assets accountable to this Policy and Procedures, within the vendor/partner's span of control.

4.5. OIT Computing Infrastructure and Services:

4.5.1. In collaboration with OIT Enterprise Data Services, ensure enhanced protections are implemented to maintain the integrity and confidentiality of information.

4.6. OIT Enterprise Data Services Team:

4.6.1. In collaboration with OIT Computing Infrastructure and Services, ensure enhanced protections are implemented to maintain the integrity and confidentiality of information.

4.7. OIT Information Asset Owner:

4.7.1. Complies with this Policy and Procedures.

4.8. OIT Information Security Office:

4.8.1. Protects the State's information systems and assets against cybersecurity threats and vulnerabilities.

4.8.2. Reviews all security logs and reports exceptions to the appropriate OIT teams.

4.9. OIT Network Services:

4.9.1. Maintains, manages, and protects communication through the State of Maine data networks, including voice and wireless networks.

4.9.2. Implements preventative physical and software measures to protect the State of Maine's networking infrastructure from unauthorized access, misuse, malfunction, modification, destruction, or improper disclosure.

4.10. State of Maine Personnel:

4.10.1. Ensure State data is being stored only on OIT-approved devices, computers, and media.

5.0. Management Commitment

The State of Maine is committed to following this policy and the supporting procedures.

6.0. Coordination Among Agency Entities

6.1. OIT coordinates system and communication protections with Agencies to ensure the security of State of Maine information assets in accordance with Title 5, Chapter 163 §1971-1985[1].

6.2. Agencies and OIT coordinate to meet all state and Federal audit documentation and reporting compliance requirements.

7.0. Compliance

[1] https://legislature.maine.gov/statutes/5/title5ch163sec0.html

7.1. For State of Maine employees, failure to comply with this document may result in progressive discipline, up to and including dismissal.

7.2. For State of Maine contractors and non-State of Maine personnel, failure to comply may result in the removal of the individual's ability to access and use State of Maine data and systems. Employers of contractors will be notified of any violations.

7.3. Personnel are also subject to any applicable penalties for statutory requirements compliance violations. Depending on the requirement and the nature of the violation, penalties could include fines and/or criminal charges.

8.0. Procedures

The following standards apply to and represent the security controls established to meet an acceptable level of protection for the State of Maine from unauthorized information system access.

8.1. **Governance Controls: Policy and Procedures (SC-1)** – The OIT develops, approves, disseminates, and reviews this policy in accordance with Sections 9.0 (Document Details) and 10.0 (Review). These sections collectively satisfy NIST SP 800-53 Revision 5 control one (1) requirements for defining, approving, disseminating, and periodically reviewing policy and procedures for this control family.

8.2. **SC Controls – Cross References:**

8.2.1. The following controls for the System and Communications Protection Policy and Procedures (SC) are published in separate policy documents:

8.2.1.1. System and Communications Protection Procedures for Defense in Depth (SC-2, 4, 5, 20, 21, 22, 23, 28, 32, 39);[2]

8.2.1.2. System and Communications Protection Procedures for Encryption Mechanisms (SC-12, 13, 17);[3] and

8.2.1.3. System and Communications Protection Procedures of Specific Technologies (SC-10, 15, 18, 40).[4]

8.2.1.4. System and Communications Protection controls applicable exclusively to Federal Tax Information (FTI), including Voice over Internet Protocol (SC-19), are addressed in IRS Publication 1075–scoped documentation and are not implemented within the general System and Communications Protection procedures.

8.3. **Boundary Protection (SC-7, (3), (4), (5), (7), (8), (9), (10), (11), (12), (15), (17), (18), (24), (29))**

[2] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SCDefenseInDepthProcedures.pdf
[3] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SCEncryptionMechanismsProcedures.pdf
[4] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SCSpecificTechnologies.pdf

8.3.1. Agency Partners, in collaboration with OIT:

8.3.1.1. Connect to external networks or information systems (see Definitions) only through managed interfaces (see Definitions) consisting of boundary protection devices (see Definitions) arranged in accordance with statewide security architecture requirements (see the General Architecture Principles[5]). Managed interfaces include, for example, gateways, routers, firewalls, network-based malicious code analysis, and virtualization systems, as well as encrypted tunnels implemented within the security architecture (e.g., routers protecting firewalls or application gateways). See the Access Control Procedures for Users Policy, AC-2[6].

8.3.2. OIT Information Asset Owners:

8.3.2.1. Protect the confidentiality and integrity of the information being transmitted across each interface in accordance with the Data Exchange Policy[7].

8.3.3. OIT Network Security Team:

8.3.3.1. Monitors and controls communications at the external boundary of information systems and at key Agency-chosen internal boundaries within the system.

8.3.3.1.1. External boundaries are monitored and controlled through the perimeter firewall.

8.3.3.1.2. Key Agency-chosen internal boundaries are monitored and controlled through the datacenter firewalls and network segmentation tools.

8.3.3.2. Implements subnetworks ("subnets") (see Definitions) using Virtual Local Area Networks for publicly accessible system components that are physically and logically separated from the internal agency network.

8.3.4. The OIT Network Security Team limits the number of external network connections to information systems using the following methods and technologies:

8.3.4.1. Circuit management;

8.3.4.2. Firewall implementation including a Web Application Firewall with Distributed Denial-of-Service infrastructure;

[5] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/general-architecture-principles_1.pdf
[6] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/access-control-procedures-for-users.pdf
[7] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/data-exchange-policy.pdf

8.3.4.3. Firewall rulesets;

8.3.4.4. Site-to-Site, user-based Virtual Private Network (VPN);

8.3.4.5. Intrusion Detection System;

8.3.4.6. Intrusion Prevention System; and

8.3.4.7. Active Directory groups.

8.3.5. The OIT Network Security Team:

8.3.5.1. Implements a managed interface for each external telecommunication service (see Definitions) to ensure all internet and foreign, untrusted partner networks are segregated onto separate firewall interfaces.

8.3.5.2. Establishes a traffic flow policy for each managed interface.

8.3.5.2.1. From time to time, the Information Security Office, at its discretion, reviews exceptions to the traffic flow policy. Traffic flow reviews also work with the application development teams to update data flow diagrams to meet federal compliance requirements (e.g., Federal Tax, Social Security, Criminal Justice, and Affordable Care Act data).

8.3.5.2.2. Exceptions that are no longer supported by an explicit mission/business need are removed.

8.3.5.2.3. Each approved exception to a traffic flow policy is documented with a supporting mission or business justification and the duration for which the exception is authorized (see Waiver Policy[8]).

8.3.5.3. The OIT Network Security Team implements technical controls to:

8.3.5.3.1. Prevent unauthorized exchange of control plane traffic with external networks;

8.3.5.3.2. Filter unauthorized control plane traffic originating from external networks; and

8.3.5.3.3. Publish or make available information necessary to enable remote networks to detect unauthorized control plane traffic originating from State-managed networks.

8.3.6. The OIT Network Security Team establishes information systems at managed interfaces to deny network communications traffic by default,

[8] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/Waiver.pdf

and allow network communications traffic by exception (i.e., deny all, permit by exception).

8.3.6.1. OIT-managed firewalls universally enforce a deny-all-allow-by-exception rule for all external traffic seeking entry to the State network. Also, all access is universally secured by authentication credentials and is encrypted both at rest and in motion. See Access Control Policy and Procedures (AC-1)[9] for more information.

8.3.6.2. This applies to the inbound network communications traffic to ensure only those connections that are essential and approved by the Chief Information Security Officer (CISO) are allowed.

8.3.6.2.1. Restrict Incoming Communications Traffic (SC-7(11))

8.3.6.2.1.1. OIT restricts incoming network communications traffic to agency-defined authorized sources and destinations through centrally managed perimeter security infrastructure.

8.3.6.2.1.2. These controls include the use of firewalls, access control lists (ACLs), demilitarized zones (DMZs), and dedicated virtual private network (VPN) tunnels to enforce policy-based routing and ingress control in accordance with the Access Control Policy and Procedures (AC-1)[10].

8.3.6.3. For outbound traffic, the CISO reviews and bans traffic by exception.

8.3.6.4. **Split Tunneling for Remote Devices (SC-7(7))** - OIT centrally manages all configurations related to split tunneling for remote access to State systems.

8.3.6.4.1. Only authorized OIT personnel may configure or modify split tunneling settings.

8.3.6.4.2. State-managed virtual private network (VPN) services enforce host posture validation during connection attempts, including certificate-based

[9] https://www.maine.gov/oit/policies/AccessControlPolicy.pdf
[10] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/AccessControlPolicy.pdf

authentication, verification of approved security agents, and confirmation of compliant encryption mechanisms.

8.3.7. The OIT Network Security Team implements host-based boundary protection mechanisms to separate information system components supporting missions and/or business functions, including:

8.3.7.1. Restricting rogue devices (see Definitions) from manipulating the State's routing tables.

8.3.7.2. Implementing a firewall authentication mechanism (see Definitions) to provide accountability for the individual and to ensure device configuration does not become corrupted with false entries.

8.3.7.3. Screening internal network addresses from an external view.

8.3.7.4. Configuring local user accounts on network firewalls to eliminate possible extended outages.

8.3.7.4.1. Local accounts are configured to only be used when the device cannot contact the central unit.

8.3.7.4.2. During normal operation, the local account exists but is not used.

8.3.7.5. Keeping passwords for firewalls in a secure, encrypted form (see Identification and Authentication Policy and Procedures[11] (IA), intranet only).

8.3.7.6. Limiting temporary or emergency port openings to no more than 31 days, at which time the port is closed, or additional hardening (see Definitions) is developed.

8.3.7.7. Implementing logging features on State network firewalls to capture all packets dropped or denied by the firewall.

8.3.7.7.1. From time to time, the Information Security Office, at its discretion, reviews State network firewall logs.

8.3.7.8. Implements firewall rulesets to always block the following types of network traffic:

8.3.7.8.1. Unauthorized scanning activity.

8.3.7.8.2. Inbound network traffic from a non-authenticated source system with a destination address of the firewall system itself.

[11] http://inet.state.me.us/oit/policies/documents/IdentificationAuthenticationPolicy.pdf

8.3.7.8.3. Inbound network traffic with a source address indicating that the packet originated on a network behind the firewall.

8.3.7.8.4. Inbound network traffic containing IP Source Routing Information (see Definitions).

8.3.7.8.5. Inbound or outbound network traffic containing a source or destination address of 0.0.0.0 and/or containing directed broadcast addresses (see Definitions).

8.3.7.9. Installs firewalls in datacenter locations that are physically secure from tampering.

8.3.7.10. Restricts firewall configurations and associated documentation information to authorized personnel within the Network Security Team, including authorized administrators, auditors, and security oversight personnel.

8.3.7.11. Authenticated Proxy Routing (SC-7(8))

8.3.7.11.1. OIT routes externally facing network traffic through authenticated proxy services implemented at managed interfaces. These proxy services restrict direct connectivity to external networks, enforce approved traffic paths, and support logging and inspection of network communications.

8.3.7.11.2. Externally accessible web traffic is processed through OIT-managed reverse proxy and Web Application Firewall (WAF) services to conceal internal system addresses and reduce exposure to network-based threats.

8.3.7.12. Networked Privileged Access (SC-7(15))

8.3.7.12.1. Privileged access to State of Maine information systems is routed through centrally managed access control interfaces, including virtual private networks (VPNs) and secure administrative gateways.

8.3.7.12.2. These interfaces enforce access control policies and support audit logging to ensure accountability and traceability of privileged activities.

8.3.8. The OIT Network Security Team isolates boundary protection mechanisms from other internal information system components by

implementing physically separate subnetworks with managed interfaces to other components of the system.

8.3.8.1. Network routing controls are implemented to supplement equipment identification by allowing specific equipment to connect only from specified external networks or internal subnetworks.

8.3.8.2. Access points between Non-Protected systems (standard agency information systems or untrusted networks) and any system components in the protected agency information system are restricted.

8.3.8.2.1. OIT allows only inbound and outbound traffic that is necessary for the protected agency information system.

8.3.8.3. Critical System Component Segmentation (SC-7(29))

8.3.8.3.1. Within OIT-managed data centers, physically and logically separate subnetworks are established to isolate critical system components and functions from noncritical systems.

8.3.8.3.2. Network segmentation requirements are enforced through dedicated subnets and routing controls to reduce the risk of compromise and limit the impact of security events affecting noncritical systems.

8.3.8.4. Restrict Threatening Outgoing Communications (SC-7(9))

8.3.8.4.1. OIT deploys network security controls, including intrusion detection and prevention systems, firewalls with outbound filtering, and threat intelligence integrations, to detect and automatically deny outgoing communications traffic that exhibits malicious characteristics or poses a threat to external systems.

8.3.8.4.2. Security event data related to denied outbound activity is centrally collected and correlated using OIT-managed security monitoring platforms. The Security Operations Center (SOC) continuously monitors these events and responds using a risk-based triage and escalation process.

8.3.8.5. Prevent Information Exfiltration (SC-7(10))

8.3.8.5.1. OIT monitors network traffic for anomalous patterns and indicators of potential information exfiltration. Network activity is analyzed through centralized security monitoring platforms to support detection, investigation, and response to suspected data loss events.

8.3.8.5.2. Response actions are coordinated by the Security Operations Center (SOC) in accordance with established risk management procedures and threat intelligence inputs.

8.3.8.6. Automated Enforcement of Protocol Formats (SC-7(17))

8.3.8.6.1. OIT mitigates protocol format risks through centralized logging, security monitoring, intrusion detection and prevention signatures, strict configuration management, and Security Operations Center (SOC)-integrated incident response processes.

8.3.8.6.2. These controls provide detection and response capabilities for anomalous or malformed protocol activity until automated enforcement mechanisms are fully implemented.

8.3.8.7. Personally Identifiable Information Processing at Boundaries (SC-7(24))

8.3.8.7.1. For systems that process Personally Identifiable Information (PII), OIT supports agency-driven compliance by enforcing technical access controls and documentation requirements as defined by the data-owning agencies.

8.3.8.7.2. Agencies are responsible for determining the lawful basis and regulatory requirements governing the processing of PII. Access to PII is provisioned by agencies through approved workflows based on legitimate business need.

8.3.8.7.3. Agencies define permitted uses of PII, and processing activities at system interfaces or external boundaries are governed by technical safeguards implemented by OIT, including network segmentation, role-based access controls, and endpoint protections.

8.3.8.7.4. The use of external resources for processing PII, such as cloud-based platforms or third-party services, is documented by the agency through

formal contracts and data exchange agreements (see Data Exchange Policy[12]) that identify approved exceptions and processing conditions.

8.3.8.7.5. Agencies maintain and periodically review all documented PII processing exceptions to ensure continued regulatory alignment. OIT supports these reviews by enforcing the access controls, logging, and data handling provisions defined within approved agreements.

8.3.9. The OIT Network Security Team implements fail-safe mechanisms to ensure information systems fail closed (see Definitions) and to prevent information systems from entering into unsecure states in the event of an operational failure of a boundary protection device.

8.3.10. The following NIST publications are recommended as guidance for the specified information technology:

8.3.10.1. NIST SP 800-41, Revision 1[13] for firewalls and firewall rules.

8.3.10.2. NIST SP 800-189[14] for routers

8.3.10.3. NIST SP 800-77[15] for VPNs.

8.3.10.4. NIST SP 800-94[16] for Intrusion Detection and Prevention Systems (IDPS).

8.4. Transmission Confidentiality and Integrity (SC-8, (1), (2))

8.4.1. For OIT-controlled locations, OIT:

8.4.1.1. Implements safeguards to protect network cabling from being damaged and to reduce the possibility of unauthorized interception of data transmissions in accordance with the Telecommunications Facilities & Wiring Specifications[17] and industrial cabling standards.

8.4.1.2. Ensures all network infrastructure, access points, wiring, conduits, and cabling are within the control of authorized personnel within OIT.

[12] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/DataExchangePolicy.pdf
[13] https://csrc.nist.gov/publications/detail/sp/800-41/rev-1/final
[14] https://csrc.nist.gov/publications/detail/sp/800-189/final
[15] https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-77.pdf
[16] https://csrc.nist.gov/publications/detail/sp/800-94/rev-1/draft
[17] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/wiring-specs.pdf

8.4.1.3. Ensures all telecommunication ("telco") closets are accessible only to authorized personnel within State agencies and OIT.

8.4.2. The OIT Network Services Team:

8.4.2.1. Uses network monitoring tools and capabilities to detect and monitor for suspicious network traffic.

8.4.2.2. Secures interfaces through network demarcation between agency-controlled and non-agency-controlled/public networks.

8.4.2.3. Implements standardized authentication mechanisms to:

8.4.2.3.1. Authenticate users through Active Directory; and

8.4.2.3.2. Authenticate devices using Active Directory, Multi-Factor Authentication, and identity/access controls.

8.4.2.4. Implements secure protocols, Secure Shell/Transport Layer Security (TLS) and Internet Protocol Security (IPSec), for secure network management functions to:

8.4.2.4.1. Implement cryptographic mechanisms (see Definitions) to prevent unauthorized disclosure of information and to detect changes to information during transmission unless otherwise protected by alternative physical safeguards.

8.4.2.4.2. Maintain the confidentiality and integrity of information during preparation for transmission and during reception.

8.4.2.5. Documents and retains on file a case-by-case risk management determination, for each type of confidential information, as to the appropriateness of its encrypted transmission to a party not served by the agency's internal network (see Data Exchange Policy[18]).

8.4.2.6. Ensures all communications that transfer Sensitive Data (TLP: Amber), (TLP: Amber+Strict), and Restricted Data (TLP: Red) (see Data Exchange Policy) between web clients and web servers employ the most current secure-transport protocol that includes the most recent version of TLS.

8.4.2.7. Addresses the risk involved in the transfer of different types of data and implements safeguards through the means of

[18] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/data-exchange-policy.pdf

exchange used, such as through email, the internet, or exchange of electronic media and portable media in accordance with the Data Exchange Policy.

8.4.2.8. Monitors for anomalies or known signatures via:

8.4.2.8.1. Intrusion detection systems;

8.4.2.8.2. Intrusion prevention systems; and

8.4.2.8.3. Network behavior analysis tools.

8.4.2.9. **External Telecommunications Services (SC-8(2)) -** For external telecommunications services, OIT implements managed interfaces, establishes traffic flow policies, protects the confidentiality of transmitted information, documents and reviews approved exceptions, and implements controls to prevent, detect, and filter unauthorized control plane traffic in accordance with Boundary Protection requirements defined in Section 8.3 of this document.

8.4.3. For OIT-hosted information assets, OIT Service Teams are responsible for the fulfillment of the items below under the direction of IT Directors. For remote-hosted information assets, the hosting partner is responsible for fulfilling the items below, with oversight from IT Procurement in collaboration with Agency business partners.

8.4.3.1. Ensures enhanced protection through the implementation of TLS and/or IPSec to maintain the integrity and confidentiality of information, including, but not limited to, the following types of transmissions:

8.4.3.1.1. Internal traffic within the information system and applications;

8.4.3.1.2. Internal traffic between two or more information systems;

8.4.3.1.3. External traffic to or across the internet;

8.4.3.1.4. Connections to cloud services and remote datacenters;

8.4.3.1.5. Remote access;

8.4.3.1.6. Email;

8.4.3.1.7. FTP transmissions;

8.4.3.1.8. Web services;

8.4.3.1.9. Voice over Internet Protocol;

8.4.3.1.10. Audio and video to include video teleconferencing hardware, appliances, and/or applications; and

8.4.3.1.11. Wireless client-to-host communications.

9.0. Document Details

9.1. Initial Issue Date: July 15, 2021

9.2. Latest Revision Date: January 16, 2026

9.3. Point of Contact: PolicyTeam.OIT@Maine.Gov

9.4. Approved By: Chief Information Officer, OIT

9.5. Legal Citation: Title 5, Chapter 163: Office of Information Technology[19]

9.6. Waiver Process: Waiver Policy[20]

9.7. Distribution: Internet[21]

10.0. Review

This document will be reviewed triennially, and when substantive changes are made to Policies, Procedures, or other authoritative regulations affecting this document.

11.0. Records Management

OIT security policies, plans, and procedures fall under the *Major Administrative Policies and Procedures* and *Internal Control Policies and Directives* records management categories. They will be retained for a minimum of six years after withdrawal or replacement and then destroyed in accordance with guidance[22] provided by Maine State Archives. Retention of these documents will be subject to any future State Archives General Schedule revisions that cover these categories.

12.0. Public Records Exceptions

Under the Maine Freedom of Access Act (FOAA),[23] certain public records exceptions may limit disclosure of agency records related to information technology infrastructure and systems, as well as security plans, procedures, or risk assessments. Information contained in these records may be disclosed to the Maine State Legislature or, in the case of a political or administrative subdivision, to municipal officials or board members under conditions that protect the information from further disclosure. Any aggrieved person seeking relief for an alleged violation of the FOAA may bring suit in any Superior Court in the State.

---

[19] https://legislature.maine.gov/statutes/5/title5ch163sec0.html
[20] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/waiver.pdf
[21] https://www.maine.gov/oit/policies-standards
[22] https://www.maine.gov/sos/arc/records/state/GS1Administrative.pdf
[23] https://legislature.maine.gov/statutes/1/title1sec402.html

13.0. Definitions

13.1. Authentication Mechanism: A mechanism that verifies user identities to ensure authorized persons can access the resources they need and to keep unauthorized persons from gaining access to resources (see Identification and Authentication Policy and Procedures (IA)[24] (intranet only).

13.2. Availability: Timely and reliable access to and use of information assets.

13.3. Boundary Protection Devices: Network or system components that enforce security policy at managed interfaces by controlling, filtering, monitoring, or restricting the flow of information between networks or system components. Boundary protection devices may include firewalls, gateways, routers, intrusion detection and prevention systems, proxy services, and application gateways implemented through physical or logical means.

13.4. Confidentiality: The state of being kept private or secret, including preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.

13.5. Control Plane Traffic: Network communications used to establish, manage, and maintain network operations and routing functions, including protocols such as Border Gateway Protocol (BGP), Domain Name System (DNS), and network management or routing control communications. Control plane traffic does not carry user data but supports the operation of network infrastructure.

13.6. Cryptographic Mechanisms (Cryptographic Modules): Any combination of hardware, firmware, or software that implements cryptographic functions such as encryption, decryption, digital signatures, authentication techniques, and random-number generation.

13.7. Demilitarized Zone (DMZ): A logically or physically separated network segment positioned between trusted internal networks and untrusted external networks. A DMZ hosts publicly accessible services and limits direct access to internal systems through controlled and monitored interfaces.

13.8. Directed Broadcast Address: A special Internet Protocol (IP) address used to transmit messages and data packets to network systems.

13.9. External Telecommunications Service: An external public switched telephone and communications, or external public switched non-telephonic service that offers either wired or wireless voice and data services over a large area.

13.10. Fail Closed: The practice of a device or system being set, through either physical or software-enabled means, to shut down, preventing any further operation, when failure conditions are detected.

13.11. Firewall Authentication Mechanism: A technical control implemented on network firewalls that requires authentication of users, devices, or administrative sessions

[24] http://inet.state.me.us/oit/policies/documents/IdentificationAuthenticationPolicy.pdf

before allowing access, configuration changes, or traffic flows, providing accountability and protection against unauthorized access or configuration tampering.

13.12. Hardening: A collection of tools, techniques, and best practices to reduce vulnerability in technology applications, systems, infrastructure, firmware, and other areas.

13.13. Information System (Information Asset): Used interchangeably with Information System. A discrete, identifiable piece of information technology, including hardware, software, firmware, systems, services, and related technology assets used to execute work on behalf of OIT or another State agency. (National Institute of Standards and Technology (NIST) Special Publication (SP) 800-30).

13.14. Integrity: The accuracy and consistency (validity) of data over its lifecycle. Guarding the integrity of information assets against improper modification or destruction includes ensuring information nonrepudiation and authenticity.

13.15. IP Source Routing Information: Information that allows the sender of a packet to specify which route the packet should take on the way to its destination and on the way back.

13.16. Managed Interfaces: Designated network interfaces or architectural enforcement points that mediate and control communications between networks or system components. Managed interfaces include firewalls, gateways, routers, proxy services, encrypted tunnels, and other boundary protection mechanisms used to enforce traffic flow policies, security controls, and monitoring requirements.

13.17. Restricted Data (TLP: Red): Information classified as highly sensitive under the State Data Exchange Policy, where unauthorized disclosure, modification, or destruction could result in severe harm. Access to Restricted Data is strictly limited and subject to the highest levels of security controls and monitoring.

13.18. Reverse Proxy: A server or service that receives client requests from external networks and forwards them to internal servers on behalf of the client, while concealing internal system details, enforcing security controls, and enabling inspection, filtering, and logging of traffic.

13.19. Rogue Devices: Unauthorized devices that are connected to a system but do not have permission to access and operate within the network.

13.20. Security Information and Event Management (SIEM): A centralized platform that collects, correlates, and analyzes security event data from multiple sources to support threat detection, monitoring, investigation, and incident response activities.

13.21. Sensitive Data (TLP: Amber), (TLP: Amber+Strict): Information classified under the State Data Exchange Policy that requires protection due to potential risk if disclosed, modified, or destroyed without authorization. Access to Sensitive Data is restricted to authorized users and protected through defined security safeguards.

13.22. Subnetwork: A logically segmented piece of a larger network.

13.23. Web Application Firewall (WAF): A specialized security control that monitors, filters, and blocks web-based traffic to and from web applications to protect against application-layer attacks, unauthorized access, and malicious activity.

14.0. Abbreviations

14.1.	ACL:	Access Control List
14.2.	BGP:	Border Gateway Protocol
14.3.	CISO:	Chief Information Security Officer
14.4.	CJIS:	Criminal Justice Information Services
14.5.	CMS:	Centers for Medicare and Medicaid Services
14.6.	DMZ:	Demilitarized Zone
14.7.	DNS:	Domain Name System
14.8.	FTP:	File Transfer Protocol
14.9.	HIPAA:	Health Insurance Portability and Accountability Act
14.10.	IDPS:	Intrusion Detection and Prevention Systems
14.11.	IPSec:	Internet Protocol Security
14.12.	IRS:	Internal Revenue Service
14.13.	NIST:	National Institute of Standards and Technology
14.14.	OIT:	[Maine] Office of Information Technology
14.15.	POA&M:	Plan of Action and Milestones
14.16.	SC:	System and Communications Protection Policy and Procedures
14.17.	SIEM:	Security Information and Event Management
14.18.	SOC:	Security Operations Center
14.19.	TLP:	Traffic Light Protocol
14.20.	TLS:	Transport Layer Security
14.21.	URL:	Uniform Resource Locators
14.22.	VPN:	Virtual Private Network
14.23.	WAF:	Web Application Firewall